Microsoft Purview ISO 27701 Compliance Program

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview ISO 27701 Compliance Program 5
- What you get . . . 5
- What this delivers . . . 5
- The standard deployment model . . . 5
- Scope boundary . . . 5
- Outcome . . . 6

1. Solution Overview — Microsoft Purview ISO 27701 Compliance Program 6
- What this delivers . . . 6
- Why ISO 27701 needs Purview . . . 6
- How it works in Purview . . . 6
- What you can control . . . 7
- Benefits . . . 7
- Limitations (be honest with buyers) . . . 7
- The standard deployment model . . . 7

2. Requirements Guide — Microsoft Purview ISO 27701 Compliance Program 8
- 2.1 Microsoft 365 + Purview compliance licensing (PIMS controls + Compliance Manager) . . . 8
- 2.2 Least-privilege Purview roles with privacy role separation . . . 8
- 2.3 PIMS scope and controller/processor role decided . . . 8
- 2.4 PII classification building blocks (sensitive-information types) . . . 8
- 2.5 Existing ISO 27001 ISMS (if any) identified . . . 9
- 2.6 Retention schedule for personal data captured . . . 9
- 2.7 DSR (data-subject-request) method decided . . . 9
- 2.8 Audit logging enabled . . . 9
- 2.9 Change control for enforce-mode changes . . . 9
- Checklist . . . 10

Global Requirements — Microsoft Purview Solutions 10
- 1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 10
- 2. Purview roles (least-privilege) and portal access . . . 11
- 3. Security & Compliance PowerShell + Graph toolchain . . . 11
- 4. Data sources & scope in scope . . . 11
- 5. Compliance, records, privacy & legal stakeholders . . . 11
- 6. A pilot scope and change control . . . 12

3. Implementation Guide — Microsoft Purview ISO 27701 Compliance Program 12
- Step 1 — Baseline the posture and roles (Assess) . . . 13
- Step 2 — Design the scope and the clause-to-control map (Design) . . . 13

Step 3 — Create the pilot ISO 27701 assessment (Configure) . . . 14
Step 4 — Build the action plan and evidence register . . . 14
Step 5 — Configure the personal-data protection controls (pilot in simulation/test) . . . 15
Step 6 — Pilot and tune (the audit gate) . . . 15
Step 7 — Wire the DSR (PII-principal-request) method . . . 15
Step 8 — Promote high-impact controls to enforce (after the gate) . . . 16
Step 9 — Validate . . . 16
Step 10 — Report and expand . . . 16
5. Testing Guide — Microsoft Purview ISO 27701 Compliance Program 17
Test 1 — ISO 27701 assessment created and scored . . . 17
Test 2 — Roles separated (least privilege) . . . 17
Test 3 — Clause-to-control map complete (controller/processor) . . . 17
Test 4 — PII label published and applies . . . 17
Test 5 — Auto-labeling simulation matches PII . . . 17
Test 6 — DLP is auditing (before the gate) . . . 18
Test 7 — DLP enforces (after the gate) . . . 18
Test 8 — Retention (retention limitation) applied . . . 18
Test 9 — DSR method locates a principal's data . . . 18
Test 10 — Audit and coverage evidence . . . 18
Test 11 — Posture report produced . . . 18
Pass/fail gate . . . 18
6. Troubleshooting Guide — Microsoft Purview ISO 27701 Compliance Program 19
The ISO 27701 assessment template isn't available in Compliance Manager . . . 19
The PIMS extension doesn't layer on ISO 27001 as expected . . . 19
Compliance Score doesn't move / actions don't auto-test . . . 20
The PII label doesn't appear for pilot users . . . 20
Auto-labeling simulation shows nothing (or the wrong items) . . . 20
DLP records nothing in audit / blocks legitimate work after enforce . . . 20
A DSR (PII-principal request) returns nothing / too much . . . 20
Retention (retention limitation) behaves unexpectedly . . . 21
Role separation looks wrong . . . 21
Evidence report is empty or partial . . . 21
PowerShell can't connect or a cmdlet is missing . . . 21
7. Best Practices — Microsoft Purview ISO 27701 Compliance Program 22
8. Deliverables Summary — Microsoft Purview ISO 27701 Compliance Program 23
Documentation . . . 23

PowerShell scripts 24
What the buyer receives 24
Outcome 24
Appendix A — PowerShell Scripts 25

Executive Summary — Microsoft Purview ISO 27701 Compliance Program

White-label · Purview Solutions

ISO/IEC 27701 is the **privacy extension to ISO 27001** — the Privacy Information Management System (PIMS) that organizations adopt to demonstrate they manage **personal data (PII)** responsibly, whether as a **controller** or a **processor**. Like any management-system standard, it is **evidence-driven**: management review and certification depend on demonstrable controls and records, not intentions. Left to generic defaults, personal data isn't consistently classified, protected, retained, or disposed of — and an auditor finds no evidence the privacy controls exist.

This is a complete, deploy-it-in-order package that stands up an **ISO 27701-aligned PIMS in Microsoft Purview**: PIMS requirements mapped to the Purview controls that evidence them, scored in **Compliance Manager**, a **PII sensitivity label** and **DLP** that start in simulation/audit and are tuned before they enforce, **retention limitation** with disposition review, a **data-subject-request method**, and a **centralized evidence register**. It is written for an administrator with no prior Purview experience, and it **extends an existing ISO 27001 ISMS** rather than duplicating it.

What you get

- A plain-language Solution Overview of the PIMS program and how labels, DLP, retention, the DSR method,

and Compliance Manager work together for ISO 27701.

- A Requirements Guide with verify / implement-if-missing for every ISO 27701 prerequisite.
- An Implementation Guide of precise, ordered steps in the Microsoft Purview portal.
- Five PowerShell scripts for posture discovery, coverage validation, a cross-control evidence report,

safe remediation of gaps, and a pilot-scope group builder.

- Testing and Troubleshooting guides for a confident rollout.

What this delivers

A named, reusable set of objects — a clause-to-control map, an `ISO 27701 Evidence – Register`, a `Sensitivity Label - PII (PIMS)` label, auto-labeling (simulated first), a `DLP Policy - PII (PIMS)` policy, PII retention, and a DSR method — deployed on the assess-design-pilot model with a mandatory **DLP audit gate** before any policy enforces, and a documented rollback.

The standard deployment model

Assess → Design → Configure → Pilot (simulate/test) → Validate → Expand (enforce).

Scope boundary

The solution provides the **technical configuration and evidence**. **ISO 27701 applicability, PIMS scope, the controller/processor determination, retention schedules, DPIA/lawful-basis outcomes,**

evidence adequacy, and the certification decision are compliance/privacy/legal/auditor determinations — this is not a certification.

Outcome

A defensible ISO 27701 PIMS in Microsoft Purview — PII mapped, protected, retained, and evidenced; DLP tuned in audit before it enforces; a working DSR method; and management-review-ready evidence — proven on a pilot before you scale.

1. Solution Overview — Microsoft Purview ISO 27701 Compliance Program

What this delivers

This solution stands up an **ISO/IEC 27701-aligned privacy program in Microsoft Purview**. ISO 27701 is the **Privacy Information Management System (PIMS)** extension to ISO/IEC 27001/27002 — it adds privacy-specific controls for organizations acting as **PII controllers** (Clause 7 / its guidance) and **PII processors** (Clause 8 / its guidance). The program maps those PIMS requirements to the Microsoft Purview controls that **evidence** them, scores the posture in **Compliance Manager**, configures and **pilots the technical controls in simulation/test**, and produces an **evidence register** — so the capability is in place, validated, and defensible.

Why ISO 27701 needs Purview

- **A PIMS is evidence-driven.** Certification and management review depend on demonstrable controls and

records — not intentions. Purview supplies the technical controls (labels, DLP, retention, audit) and the evidence trail.

- **Personal data (PII) must be protected, minimized, and retained lawfully.** Sensitivity labels + DLP

protect PII; data-lifecycle/retention enforces retention limitation and disposal; audit provides accountability.

- **Controller vs processor duties differ.** ISO 27701 splits obligations for controllers and

processors; the control map records which apply and how each is evidenced.

- **It builds on ISO 27001.** Where an ISO 27001 ISMS already exists, this program **extends** it with

the privacy overlay rather than starting over.

How it works in Purview

1. **Compliance Manager** hosts an **ISO 27701** assessment (availability varies by plan/cloud — verify)

so PIMS requirements become scored **improvement actions** with owners, status, and evidence slots.

1. A **control map** ties each in-scope PIMS clause/control to the Purview control that evidences it

(labels, DLP, retention, audit, DSR method).

1. **Personal-data protection controls** — a PII sensitivity label, auto-labeling, DLP over PII, and a retention label — are configured and **piloted in simulation/audit** before enforcement.

1. A **data-subject-request (DSR) method** (Priva Subject Rights Requests where licensed, or eDiscovery/

content search) answers access/correction/erasure requests; **decisions remain privacy/legal's**.

1. An **evidence register** captures, per control, the owner, implementation/test status, and proof — the artifact an auditor or the management review reads.

What you can control

- The PIMS control map and which Purview control evidences each clause.
- The PII label taxonomy, auto-labeling, and DLP scope/actions (audit → enforce).
- Retention durations/disposition for PII (from the retention schedule — a records/legal input).
- The DSR method and the evidence-register contents.

Benefits

- **Certification-ready evidence** — PIMS controls mapped, scored, and evidenced in one place.
- **PII protected and minimized** — labels + DLP + retention piloted before they enforce.
- **Controller/processor clarity** — obligations recorded and evidenced by role.
- **Extends, doesn't replace** — layers cleanly on an existing ISO 27001 ISMS.

Limitations (be honest with buyers)

- Auto-labeling at rest, endpoint DLP, trainable classifiers, advanced records, and premium Compliance Manager assessments require **Microsoft 365 E5 / E5 Compliance** — the Requirements Guide names the licensing; **verify your licensing/tenant**.

- **ISO 27701 applicability, scope of the PIMS, controller/processor determination, retention schedules, DPIA outcomes, lawful basis, and — above all — the certification decision are compliance/privacy/legal determinations. **This solution provides the technical configuration and evidence,** not **the determination and** not** a certification.

- Purview evidences the **technical** controls; organizational PIMS controls (governance, training, contracts, supplier management) live outside Purview and are referenced, not configured here.

The standard deployment model

> ***Assess*** → ***Design*** → ***Configure*** → ***Pilot (simulate/test)*** → ***Validate*** → ***Expand (enforce)***, *with a* ***DLP audit gate*** *before any policy enforces, simulation for auto-labeling, and a documented rollback.*

2. Requirements Guide — Microsoft Purview ISO 27701 Compliance Program

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites are in `global-requirements-purview.md` (licensing, least-privilege roles, S&C PowerShell/Graph toolchain, in-scope data, compliance/records/privacy/legal stakeholders, and a pilot scope with change control) — this guide adds the **ISO 27701-specific** prerequisites and does not repeat the six.

2.1 Microsoft 365 + Purview compliance licensing (PIMS controls + Compliance Manager)

Description: Licensing that includes the capabilities the program uses. Sensitivity labels and baseline DLP ship in **Microsoft 365 E3 / Business Premium**; **auto-labeling at rest, endpoint DLP, trainable classifiers, advanced records, premium Compliance Manager assessments (including ISO 27701), and Priva** require **Microsoft 365 E5** (or the **E5 Compliance** add-on / Priva licensing). **Why:** The PIMS technical controls and the ISO 27701 assessment template are plan-gated. **Verify:** M365 admin center → **Billing** → **Licenses**; confirm the **ISO 27701** template appears in Purview → **Compliance Manager** → **Assessment templates**; run `ISO27701-Discovery.ps1`. **Verify your licensing/tenant** — availability evolves and is cloud-dependent. **Implement:** Assign the required plan/add-on before starting; confirm the assessment template and Priva (if the DSR workflow will use it) are available.

2.2 Least-privilege Purview roles with privacy role separation

Description: Least-privilege roles to create labels, DLP, retention, and to read compliance posture — e.g. **Compliance Administrator** (or **Information Protection Admin** + **Data Loss Prevention**), **Records Management** for disposition, and **Compliance Manager** assessment roles — with **HR/privacy-sensitive** roles (Insider Risk, Communication Compliance, Priva) held by **separate** owners. **Why:** Purview uses fine-grained role groups; a PIMS expects least privilege and separation of duties. **Verify:** `https://purview.microsoft.com` → **Settings** → **Roles and scopes** → **Role groups**; confirm membership and separation; capture it as `ISO 27701 Roles – Separation Evidence`. **Implement:** Assign least-privilege role groups under change control; separate privacy-sensitive roles.

2.3 PIMS scope and controller/processor role decided

Description: The **scope of the PIMS** (which workloads/systems process PII) and whether the organization acts as a **PII controller**, **PII processor**, or both for each processing activity — because ISO 27701's control set differs by role. **Why:** The control map and evidence depend on scope and role; controller and processor obligations are not identical. **Verify:** A scope statement and controller/processor determination exist per processing activity (recorded as `ISO 27701 Scope – Record`), signed off by privacy/compliance/legal. **Implement:** Convene privacy (DPO), compliance, and legal to set scope and roles **before** authoring the control map (Implementation Step 2). **The determination is deferred** to those functions.

2.4 PII classification building blocks (sensitive-information types)

Description: The **personal-data / PII sensitive-information types** the program keys off (built-in identity/health/financial SITs, EU/national identifiers, and any **custom SIT** for organization- specific PII), decided so DLP and auto-labeling detect PII accurately. **Why:** PIMS controls act on personal data; accurate detection is the basis of protection and evidence. **Verify:** The relevant SITs are identified and available in the Purview portal; sample content tests them. **Implement:** Select the built-in PII SITs; build a custom SIT where a PII pattern is organization- specific (Implementation Step 5).

2.5 Existing ISO 27001 ISMS (if any) identified

Description: Whether an **ISO/IEC 27001 ISMS** already exists (Compliance Manager assessment, Statement of Applicability, existing labels/DLP/retention) so the PIMS **extends** it rather than duplicating controls. **Why:** ISO 27701 is an extension of ISO 27001; reusing existing controls avoids conflicting policies and rework. **Verify:** Any existing ISO 27001 assessment and reusable controls are identified. **Implement:** Reference and reuse existing controls where present; only add the privacy-specific overlay.

2.6 Retention schedule for personal data captured

Description: The **retention schedule** for PII (how long each category is kept and the disposal action) — sourced from records management, privacy, and legal, not guessed. **Why:** ISO 27701 requires PII retention limitation and secure disposal; durations are records/legal decisions. **Verify:** A retention schedule source for PII exists with named approvers. **Implement:** Obtain the schedule; configure `Retention Label - PII - Retention Limitation` accordingly (Implementation Step 5). **Retention determinations are deferred** to records/privacy/legal.

2.7 DSR (data-subject-request) method decided

Description: How the organization will fulfil **data-subject requests** (access, correction, erasure, portability) — **Microsoft Priva Subject Rights Requests** where licensed, or Purview **eDiscovery/content search** as the locate method. **Why:** ISO 27701 requires a method to meet PII-principal rights; Purview provides the locate/produce tooling. **Verify:** The chosen method is available (Priva licensing or eDiscovery) and a runbook owner is named. **Implement:** Wire the method (Implementation Step 7). **Erasure/production decisions remain privacy/legal.**

2.8 Audit logging enabled

Description: Microsoft Purview **audit** (unified audit log) is on — the accountability evidence source for the PIMS. **Why:** Accountability and evidence (management review, certification) read audit/activity data. **Verify:** Purview → **Audit** returns results; run `ISO27701-EvidenceReport.ps1`. **Implement:** Turn on auditing in the Purview **Audit** solution; allow time to populate.

2.9 Change control for enforce-mode changes

Description: A documented change-control / rollback process for switching DLP from audit to enforce, turning auto-labeling out of simulation, or activating a retention policy that deletes PII. **Why:** Enforce-mode DLP can block legitimate work; auto-labeling mistakes are user-visible; retention deletion is irreversible. **Verify:** A change ticket exists with an approver, a pilot scope, and a documented rollback. **Implement:** Record the change, name `ISO 27701 - Pilot Scope`, define the rollback, and get approval before enforcing.

Checklist

• M365 + Purview licensing (E3/Business Premium for labels + basic DLP; **E5 / E5 Compliance** for advanced controls + ISO 27701 assessment + Priva) — `ISO27701-Discovery.ps1`

• Least-privilege Purview roles + privacy role separation — `ISO 27701 Roles – Separation Evidence`

• PIMS scope + controller/processor role decided (determination deferred) — `ISO 27701 Scope – Record`

• PII sensitive-information types identified (built-in + custom where needed)

• Existing ISO 27001 ISMS identified for reuse (extend, don't duplicate)

• PII retention schedule captured (records/privacy/legal)

• DSR method decided (Priva or eDiscovery/content search)

• Purview audit logging enabled — `ISO27701-EvidenceReport.ps1`

• Change control + rollback for enforce-mode / auto-labeling / retention deletion

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

- **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is visible in the Purview portal.
- **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

- **Description:** Access with the least-privilege **Purview / compliance role** the solution names (e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.
- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.
- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.
- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.
- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.
- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.
- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.
- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.
- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview ISO 27701 Compliance Program

Follow these steps **in order**, primarily in the **Microsoft Purview portal** (`https://purview.microsoft.com`) and (for the managed DSR workflow) the **Microsoft Priva** portal. Portal paths and cmdlets are current at authoring; Purview evolves and features are licensing-/cloud-dependent — **verify your licensing/tenant** and treat any absent feature as a plan/cloud gap (Requirement 2.1), not a step error.

> ***Model:*** *Baseline the posture and roles, design the clause-to-control map with compliance/privacy/legal, create the ISO 27701 assessment and evidence register, wire the DSR method, and* ***pilot every high-impact technical control in simulation/test*** *before enforcing — validating each on* `ISO 27701 - Pilot Scope` *before you expand. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot (simulate)*** *→* ***Validate*** *→* ***Expand.***
>
> ***Determinations stay with the business.*** *ISO 27701 applicability, PIMS scope, the controller/processor determination, retention schedules, DPIA/lawful-basis outcomes, evidence adequacy, and the* ***certification decision*** *are* ***compliance/privacy/legal*** *calls. This guide configures the method and*

collects evidence; it does not make the ruling and is not a certification.

The named objects created below are reused verbatim in Testing, Troubleshooting, and the scripts:

Object	Name
ISO 27701 assessment (pilot → production)	`ISO 27701 Assessment – PIMS – Pilot`, `ISO 27701 Assessment – PIMS – Production`
Clause → control map	`ISO 27701 Control Map – Clauses`
Action plan / evidence register	`ISO 27701 Action Plan – Pilot`, `ISO 27701 Evidence – Register`
Scope / role record	`ISO 27701 Scope – Record`
Role-separation evidence	`ISO 27701 Roles – Separation Evidence`
Sensitivity label	`Sensitivity Label - PII (PIMS) - All Users`
Auto-labeling policy	`Auto-Label - PII - Pilot`
DLP policy	`DLP Policy - PII (PIMS) - Audit` (renamed `... - Enforce` at the gate)
Retention label	`Retention Label - PII - Retention Limitation`
DSR access search (content-search method)	`DSR - PII Principal Access - Search`
Posture report	`ISO 27701 Posture – Report`

Step 1 — Baseline the posture and roles (Assess)

1. Confirm licensing (Requirement 2.1) and that the **ISO 27701** assessment template is available in Purview → **Compliance Manager** → **Assessment templates**.

1. Run `ISO27701-Discovery.ps1` to capture the current state: existing labels, DLP policies (and mode), retention policies, the **PII sensitive-information types**, whether an **ISO 27001** assessment already exists (reuse), and the Purview **role groups** and their members.

1. Confirm least-privilege **role separation** (Requirement 2.2); save the role snapshot as `ISO 27701 Roles – Separation Evidence`.

1. **Gate:** licensing confirmed, ISO 27701 template visible, roles separated. If the template is missing, re-check the plan (Requirement 2.1) before proceeding.

Step 2 — Design the scope and the clause-to-control map (Design)

1. With compliance/privacy (DPO), records, and legal, confirm the **PIMS scope** and the **controller/processor** role per processing activity; record it as `ISO 27701 Scope – Record`.

1. Build `ISO 27701 Control Map – Clauses` — map each in-scope PIMS requirement to the Purview control

that evidences it. A common baseline:

ISO 27701 area (PIMS)	Purview control (evidence)
PII protection / security of processing (extends ISO 27001 A.8, A.5)	**Sensitivity labels** (+ encryption), **DLP** over PII, access controls
Retention limitation & secure disposal	**Data lifecycle / retention** labels & policies; disposition review
Accountability & logging	**Audit** (unified audit log); Compliance Manager evidence register
PII principal rights (access / correction / erasure)	**DSR method**: Priva SRR or eDiscovery/content search
Privacy by design & default	**Default/mandatory labeling**, DLP defaults, retention defaults
Records of PII processing	Documentation (a legal artifact; Purview evidences the technical controls)
Controller/processor-specific duties	Recorded per role in the map; evidenced by the applicable controls

1. Applicability, scope, controller/processor role, and records content are the stakeholders'

determinations — capture the decisions, not assumptions. **Reuse existing ISO 27001 controls** (Requirement 2.5) rather than duplicating them.

Step 3 — Create the pilot ISO 27701 assessment (Configure)

1. Purview → **Compliance Manager** → **Assessments** → **Add assessment**.
2. Choose the **ISO 27701** template (layered on your **ISO 27001** assessment where present).
3. **Name:** `ISO 27701 Assessment – PIMS – Pilot`. Assign the **group/scope** and create it.
4. The assessment now lists **improvement actions**, each with a score impact, an owner field, an

implementation status, a test status, and an evidence slot.

Step 4 — Build the action plan and evidence register

1. In `ISO 27701 Assessment – PIMS – Pilot`, assign each improvement action an **owner** and a target

date — this is `ISO 27701 Action Plan – Pilot`.

1. Create the **evidence register** `ISO 27701 Evidence – Register` — for each mapped control, record the

owner, implementation status, test status, and the proof location (policy name, audit export, screenshot, or `ISO27701-EvidenceReport.ps1` CSV).

1. Enable **automatic testing** where eligible: Purview → **Compliance Manager** → **Settings** → turn on

automatic testing of Microsoft-managed actions. Only eligible actions auto-test; the rest are manual — verify availability.

Step 5 — Configure the personal-data protection controls (pilot in simulation/test)

> *Each high-impact control below is **referenced** by the program and evidenced here; it is piloted in **simulation/test** on `ISO 27701 - Pilot Scope` before enforcement. Where the organization already runs a PII DLP pack or a label taxonomy (or an ISO 27001 control), **reuse and evidence** it rather than re-creating it.*

1. **Sensitivity label.** Purview → **Information Protection** → **Sensitivity labels** → **Create a label** →

`Sensitivity Label - PII (PIMS) - All Users` (scope **Items**; configure encryption if the classification requires it). Publish it to `ISO 27701 - Pilot Scope` via a label policy.

1. **Auto-labeling (simulation). Information Protection** → **Auto-labeling** → **Create** →

`Auto-Label - PII - Pilot`; condition = the **PII sensitive-information types** (Requirement 2.4); apply the label above; choose **Run policy in simulation mode** — do **not** turn it on.

1. **DLP in audit. Data Loss Prevention** → **Policies** → **Create** → `DLP Policy - PII (PIMS) - Audit`;

locations = Exchange, SharePoint, OneDrive, Teams, Devices (as licensed), scoped to `ISO 27701 - Pilot Scope`; rule matches the PII SITs and/or the label; action = **audit only** (policy tips on, no block); **Run the policy in test mode**.

1. **Retention (retention limitation). Data Lifecycle Management** → **Retention labels** → **Create** →

`Retention Label - PII - Retention Limitation` (duration/end action **from the retention schedule** — Requirement 2.6, a records/legal input, not a guess); use **disposition review** so nothing is auto-deleted unreviewed. Publish/auto-apply to the pilot scope.

Step 6 — Pilot and tune (the audit gate)

1. Let the audit-mode DLP and simulation auto-labeling run against `ISO 27701 - Pilot Scope` for the

agreed window.

1. Review matches in Purview → **Data Loss Prevention** → **Alerts** / **Activity explorer** and the

auto-labeling **Simulation**; run `ISO27701-EvidenceReport.ps1` for a coverage + DLP-event summary.

1. Tune out false positives (confidence levels, instance counts, exceptions).

2. **Gate:** only when the audit shows the controls match real PII and not routine work do you promote

to enforce (Step 8). If still noisy, keep tuning — do not enforce.

Step 7 — Wire the DSR (PII-principal-request) method

1. **If Priva is licensed:** Priva portal → **Subject Rights Requests** → **Create request** — configure the

request type (access/export/tag for follow-up), the data subject, and the connectors; use it as the managed locate-review-produce workflow.

1. **If Priva is not licensed:** use Purview **eDiscovery (Standard/Premium)** / content search — create a content search `DSR - PII Principal Access - Search` keyed on the principal's identifiers across the in-scope workloads, review, and export.

1. Document the **DSR runbook**: intake → verify identity → locate (`DSR - PII Principal Access - Search or Priva SRR) → review → privacy/legal decision → produce/correct/erase → record in ISO 27701 Evidence – Register`. **Erasure/production decisions remain privacy/legal.**

Step 8 — Promote high-impact controls to enforce (after the gate)

1. **DLP → enforce.** Open `DLP Policy - PII (PIMS) - Audit` → **Edit**; rename to `DLP Policy - PII (PIMS) - Enforce`; change the action to **Block** (or **Block with override**) as the business requires; **Turn the policy on** for the pilot scope first.

1. **Auto-labeling → on.** After the simulation is clean, turn `Auto-Label - PII - Pilot` on (out of simulation).

1. **Rollback (if needed):** set the DLP policy back to **Test mode**, turn auto-labeling back to simulation, or disable the retention policy. Deletion is irreversible — validate first.

Step 9 — Validate

1. Complete the Testing Guide against `ISO 27701 - Pilot Scope`.
2. Run `ISO27701-Validation.ps1` (label published, DLP present + mode, retention present, audit on) and `ISO27701-EvidenceReport.ps1` (classification + DLP-event coverage; audit sample).

1. Run a **test DSR** end to end (Step 7 method) and record it in `ISO 27701 Evidence – Register`.
2. **Gate:** all pass/fail gates in the Testing Guide met; evidence recorded for each mapped control.

Step 10 — Report and expand

1. Produce `ISO 27701 Posture – Report` from Compliance Manager (score, per-action status, evidence) plus the `ISO27701-EvidenceReport.ps1` coverage output.

1. Promote the assessment to `ISO 27701 Assessment – PIMS – Production`; widen the label policy, the DLP enforce policy, and the retention policy from `ISO 27701 - Pilot Scope` to broader groups (or **All users / All locations**) once the pilot passes.

1. Re-validate each expansion with `ISO27701-Validation.ps1` and `ISO27701-EvidenceReport.ps1`; run the

maintenance cadence (re-score, re-test, refresh evidence) on a defined schedule ahead of management review / certification. **The certification decision is the auditor's/organization's, not this solution's.**

Order of operations

`Baseline + roles → scope + role + clause map → ISO 27701 assessment (pilot) → action plan + evidence register → PII controls (simulation/audit) → audit gate → DSR method wired → enforce (after gate) → validate + test DSR → report + expand`

5. Testing Guide — Microsoft Purview ISO 27701 Compliance Program

Run after the pilot assessment and controls are configured on `ISO 27701 - Pilot Scope` (Implementation Steps 3–7), **before** the audit gate (Step 6), and again after each expansion. Each test states what to **do** and the **expected** result; the pass/fail gate is at the end.

Test 1 — ISO 27701 assessment created and scored

Do: Purview → **Compliance Manager** → **Assessments** → open `ISO 27701 Assessment – PIMS – Pilot`. **Expected:** The assessment exists against the **ISO 27701** template (layered on ISO 27001 where present), shows a **Compliance Score**, and lists improvement actions with owner / implementation status / test status / evidence slots.

Test 2 — Roles separated (least privilege)

Do: Purview → **Settings** → **Roles and scopes** → **Role groups**, or run `ISO27701-Discovery.ps1` (role report). **Expected:** The mapped roles are least-privilege and HR/privacy-sensitive roles (Insider Risk, Communication Compliance, Priva) are held by **separate** owners — captured as `ISO 27701 Roles – Separation Evidence`.

Test 3 — Clause-to-control map complete (controller/processor)

Do: Review `ISO 27701 Control Map – Clauses`, `ISO 27701 Scope – Record`, and `ISO 27701 Evidence – Register`. **Expected:** Every in-scope PIMS requirement maps to a named Purview control with an owner and an evidence location; the **controller/processor role** is recorded per activity; no in-scope requirement is unmapped.

Test 4 — PII label published and applies

Do: As a pilot user in Word/Outlook, open the **Sensitivity** button; apply `Sensitivity Label - PII (PIMS) - All Users` to a test document. Or run `ISO27701-Validation.ps1`. **Expected:** The label appears via its label policy and (if encryption is configured) protects the document per its permissions.

Test 5 — Auto-labeling simulation matches PII

Do: Purview → **Information Protection** → **Auto-labeling** → open `Auto-Label - PII - Pilot` → **Simulation**. **Expected:** The simulation lists items containing **PII sensitive-information types** and does not flag routine, non-personal content.

Test 6 — DLP is auditing (before the gate)

Do: As a pilot user, email a test message containing a fake **PII identifier** to an external address; check Purview → **Data Loss Prevention** → **Alerts** / **Activity explorer**. Or run `ISO27701-EvidenceReport.ps1`. **Expected:** `DLP Policy - PII (PIMS) - Audit` records the match (policy tip shown, no block) — the audit gate has data to review.

Test 7 — DLP enforces (after the gate)

Do: After Implementation Step 8, repeat Test 6 against `DLP Policy - PII (PIMS) - Enforce`. **Expected:** The action now blocks (or blocks-with-override) per the enforce rule; the event is logged.

Test 8 — Retention (retention limitation) applied

Do: Apply `Retention Label - PII - Retention Limitation` to a test item and attempt to delete it before the period. Or run `ISO27701-Validation.ps1`. **Expected:** The item is retained/dispositioned per the schedule; disposition review holds deletion for review rather than auto-deleting.

Test 9 — DSR method locates a principal's data

Do: Run the DSR method from Implementation Step 7 — a Priva **Subject Rights Request**, or the content search `DSR - PII Principal Access - Search` keyed on a test principal's identifiers. **Expected:** The request/search returns the test principal's PII across the in-scope workloads; the run is recorded in `ISO 27701 Evidence – Register`. (The produce/correct/erase **decision** is privacy/legal, not part of this test.)

Test 10 — Audit and coverage evidence

Do: Run `ISO27701-EvidenceReport.ps1`. **Expected:** A label inventory, a DLP service/mode matrix, a per-workload DLP-event count, and an audit-log sample — the cross-control evidence for the register.

Test 11 — Posture report produced

Do: Produce `ISO 27701 Posture – Report` (Compliance Manager score + `ISO27701-EvidenceReport.ps1` output). **Expected:** A score, per-action status, and evidence summary suitable for management review / an external auditor.

Pass/fail gate

Gate	Requirement
Design pass	Tests 1–3 pass — assessment scored, roles separated, clause map complete with controller/processor role

Gate	Requirement
Pilot pass	Tests 4–6, 8, 9 pass on `ISO 27701 - Pilot Scope`; DLP audit shows real PII matches with acceptable noise
Audit gate	DLP audit reviewed and tuned; only then is Test 7 (enforce) run
Expand pass	Tests 4, 6/7, 8, 10, 11 pass after widening scope beyond the pilot; evidence refreshed in `ISO 27701 Evidence – Register`

6. Troubleshooting Guide — Microsoft Purview ISO 27701 Compliance Program

Common field issues for the ISO 27701 PIMS program and how to resolve them. Objects are named verbatim from the Implementation Guide. Most problems are **licensing/cloud gaps**, **replication delay**, or **audit not-yet-tuned** — not step mistakes. When a feature is simply absent, treat it as a plan/cloud gap (Requirement 2.1) and **verify your licensing/tenant** first. Remember the boundary: **ISO 27701 applicability, PIMS scope, the controller/processor determination, retention schedules, evidence adequacy, and the certification decision are compliance/privacy/legal/auditor determinations** — the tooling configures and evidences, it does not decide and is not a certification.

The ISO 27701 assessment template isn't available in Compliance Manager

• **Symptom:** `ISO 27701 Assessment – PIMS – Pilot` can't be created; the **ISO 27701** template is

missing.

• **Likely cause:** Premium Compliance Manager assessments need **Microsoft 365 E5 / E5 Compliance**;

availability varies by cloud.

• **Resolve:** Run `ISO27701-Discovery.ps1`; confirm the plan; **verify your tenant.** Where the template

is absent, evidence the mapped controls against the available baseline (e.g. an ISO 27001 assessment) and record the gap.

The PIMS extension doesn't layer on ISO 27001 as expected

• **Symptom:** Controls appear duplicated or conflicting with an existing ISO 27001 program.

• **Likely cause:** The PIMS was built as a parallel program rather than **extending** the existing ISMS

(Requirement 2.5).

• **Resolve:** Identify the existing ISO 27001 assessment and reusable controls; **reuse and evidence**

them; only add the privacy-specific overlay. Record the reuse in `ISO 27701 Control Map – Clauses`.

Compliance Score doesn't move / actions don't auto-test

- **Symptom:** After configuring controls, the score or action status doesn't update.
- **Likely cause: Automatic testing** isn't enabled, the action isn't eligible, or testing latency.
- **Resolve:** Purview → **Compliance Manager** → **Settings** → enable automatic testing; note only eligible

Microsoft-managed actions auto-test — the rest are **manual** and evidenced by hand in `ISO 27701 Evidence – Register`. Allow time to reflect.

The PII label doesn't appear for pilot users

- **Symptom:** `Sensitivity Label - PII (PIMS) - All Users` isn't visible in Word/Outlook.
- **Likely cause: Replication delay**, the user isn't in `ISO 27701 - Pilot Scope`, or the client

hasn't refreshed.

- **Resolve:** Confirm publication with `ISO27701-Validation.ps1`; verify pilot-group membership

(`ISO27701-Set-Scope.ps1`); restart the Office client; allow propagation before re-publishing.

Auto-labeling simulation shows nothing (or the wrong items)

- **Symptom:** `Auto-Label - PII - Pilot` simulation is empty or flags routine content.
- **Likely cause:** Simulation still crawling; the condition doesn't use the **PII sensitive-information

types**; no matching content in the in-scope locations.

- **Resolve:** Let the simulation complete; confirm the rule uses the PII SITs (Requirement 2.4) and

applies the correct label; seed a pilot site with test PII content; re-run. Never turn the policy on until the simulation is clean.

DLP records nothing in audit / blocks legitimate work after enforce

- **Symptom:** No events from `DLP Policy - PII (PIMS) - Audit`, or `... - Enforce` blocks routine work.
- **Likely cause:** Policy still deploying, **audit off** (Requirement 2.8), location out of scope; or the

policy was promoted before the **audit gate** was clean.

- **Resolve:** Confirm auditing is on and returning results (`ISO27701-EvidenceReport.ps1`); verify

locations/scope. If enforce over-blocks, **roll back** to **Test mode**, tune out false positives, and re-enforce only after the gate passes.

A DSR (PII-principal request) returns nothing / too much

- **Symptom:** The Priva Subject Rights Request or the content search `DSR - PII Principal Access - Search`

misses or over-returns.

- **Likely cause:** Wrong/insufficient identifiers, workloads out of scope, or indexing delay.
- **Resolve:** Broaden the identifiers; confirm all in-scope workloads are searched; allow indexing time.

Record the run in `ISO 27701 Evidence – Register`. **The correct/erase/produce decision is privacy/legal** — the tooling locates and produces.

Retention (retention limitation) behaves unexpectedly

- **Symptom:** `Retention Label - PII - Retention Limitation` retains or deletes wrongly.
- **Likely cause:** Policy still propagating; wrong locations; duration/end-action from a **guess**.
- **Resolve:** Confirm the policy is **On** and scoped (`ISO27701-Validation.ps1`); use **disposition review**. Retention durations are a records/legal determination** — confirm the schedule before activating deletion. Deletion is irreversible.

Role separation looks wrong

- **Symptom:** Insider Risk / Communication Compliance / Priva roles held by the same owner as configuration roles.
- **Likely cause:** Over-broad role assignment.
- **Resolve:** Separate the privacy-sensitive roles from configuration roles; re-capture `ISO 27701 Roles – Separation Evidence via ISO27701-Discovery.ps1`. Separation of duties is a PIMS control.

Evidence report is empty or partial

- **Symptom:** `ISO27701-EvidenceReport.ps1` produces little evidence.
- **Likely cause:** Audit off; DLP not yet auditing; labels/retention not yet published; read-access gaps.
- **Resolve:** Enable audit (Requirement 2.8); confirm the controls are configured and auditing; re-run after events accumulate; confirm the operator holds the read roles.

PowerShell can't connect or a cmdlet is missing

- **Symptom:** `Connect-IPPSSession` / `Connect-MgGraph` fails or a cmdlet is unavailable.
- **Likely cause:** Modules missing/old, or MFA/modern-auth blocked.
- **Resolve:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser` (and Microsoft.Graph for the scope script); sign in with an MFA-capable Compliance Administrator; retry. A cmdlet still missing after a good connection is a plan/cloud gap — **verify your tenant.**

Escalation & rollback

Situation	Action
DLP enforce disrupts work	Revert to **Test mode** (audit); fix exceptions; re-run the audit gate
Auto-labeling mislabels	Return the policy to **simulation**; fix the rule; re-simulate
Retention deleting wrongly	Disable the retention policy; enable **disposition review**; confirm the schedule with records/legal
Feature genuinely absent	Treat as licensing/cloud gap (Req 2.1) — **verify your licensing/tenant**
Applicability / scope / controller-processor / certification question	**Determination deferred** to compliance/privacy/legal/auditor — capture, don't decide

7. Best Practices — Microsoft Purview ISO 27701 Compliance Program

• **Extend the ISMS, don't rebuild it.** ISO 27701 is the privacy extension of ISO 27001 — layer the

PIMS assessment on the existing ISO 27001 assessment and **reuse** existing labels, DLP, and retention controls rather than creating parallel ones that conflict.

• **Record controller vs processor per activity.** ISO 27701's obligations differ by role — capture the

determination in `ISO 27701 Scope – Record` and map the applicable controls accordingly. The determination is privacy/legal's; capture it, don't invent it.

• **Map every in-scope clause to a Purview control — and a piece of evidence.** `ISO 27701 Control Map –

Clauses plus ISO 27701 Evidence – Register` are the heart of the program. Configuration without evidence is not a PIMS.

• **Detect PII accurately.** Use the built-in PII sensitive-information types and add a custom SIT for

organization-specific PII; accurate detection is what makes labels, DLP, and DSRs trustworthy.

• **Simulate auto-labeling.** Always run `Auto-Label - PII - Pilot` in simulation and review matches

before turning it on — it labels PII at scale and mistakes are user-visible.

• **Audit DLP before you enforce.** Run `DLP Policy - PII (PIMS) - Audit` in test mode, review matches,

tune out false positives, and only then enforce. A blocked-work storm is the fastest way to lose trust in DLP.

• **Retention limitation with disposition review.** Set PII retention from the schedule (a records/legal

determination), not a guess; use disposition review so nothing is auto-deleted unreviewed. Deletion is irreversible.

• **Wire and test a real DSR.** A PIMS must actually answer PII-principal rights — run a **test DSR** end

to end and record it. Keep the produce/correct/erase **decision** with privacy/legal; the tooling locates and produces.

• **Separate privacy-sensitive roles.** Hold Insider Risk / Communication Compliance / Priva roles apart from configuration roles; capture `ISO 27701 Roles – Separation Evidence`. Separation of duties is a control.

• **Name every object by purpose and stage.** Use `<Purpose> - <Scope> - <Stage>` (rename `... - Audit` to `... - Enforce` at the gate) so the portal shows exactly where each control sits.

• **Evidence continuously, ahead of certification.** Work the mapped improvement actions in Compliance Manager as you configure, and refresh evidence on a cadence before management review — but remember the **certification decision is the external auditor's/organization's, not this solution's.**

• **Verify licensing and cloud.** Advanced controls, the ISO 27701 assessment template, and Priva need E5 / E5 Compliance / Priva licensing — **verify your licensing/tenant** rather than assuming a feature is present.

• **Document the objects and the rollback.** Record the control map, label/policy names, scopes, DSR method, and the rollback (revert DLP to audit; auto-labeling to simulation; disable a retention policy) for repeatability and change control.

8. Deliverables Summary — Microsoft Purview ISO 27701 Compliance Program

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box
1. Solution Overview	What the ISO 27701 PIMS program is — Compliance Manager scoring, clause-to-control mapping, DSR method, and evidence — benefits and limitations
2. Requirements Guide	Every ISO 27701-specific prerequisite with Verify / Implement-if-missing
Global Requirements (Purview)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered steps: baseline & roles, scope + controller/processor + clause map, ISO 27701 assessment, action plan & evidence register, PII controls (simulation/audit), DSR method, enforce, validate, expand
5. Testing Guide	Validation procedures with pass/fail gates and the DLP audit gate

Document	Purpose
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations

PowerShell scripts

Script	What it does
`ISO27701-Discovery.ps1`	Reports the tenant's PIMS-relevant posture — labels, DLP policies (and mode), retention, PII sensitive-information types, any existing ISO 27001 assessment (reuse), audit signal, and Purview role groups (role-separation readiness); read-only
`ISO27701-Validation.ps1`	Confirms the named objects are in place — PII label published, DLP present (and its mode), retention present, audit on — pass/fail with exit code
`ISO27701-EvidenceReport.ps1`	Cross-control evidence: label inventory, DLP service/mode matrix, per-workload DLP-event counts, and an audit-log sample — optionally exported to CSV for `ISO 27701 Evidence – Register`
`ISO27701-Remediation.ps1`	Safe remediation of low-risk gaps (default `-WhatIf`) — enables a disabled label/retention policy; **never** auto-enforces DLP (the audit gate is a human decision)
`ISO27701-Set-Scope.ps1`	Builds/updates the `ISO 27701 - Pilot Scope` Microsoft Entra security group for piloting and expansion

What the buyer receives

- This implementation guide as a Word document and PDF.
- All five PowerShell scripts in a single ZIP.
- A repeatable program following the model: **Assess → Design → Configure → Pilot (simulate) →

Validate → Expand**, with a DLP audit gate before enforce, a wired DSR runbook, and a documented rollback.

Outcome

An ISO/IEC 27701-aligned PIMS in Microsoft Purview — PIMS requirements mapped to Purview controls, scored in Compliance Manager, personal-data protection piloted in simulation/audit before it enforces, a DSR method that answers PII-principal requests, and a centralized evidence register — configured, validated, and **defensible**. ISO 27701 applicability, PIMS scope, the controller/processor determination, retention schedules, evidence adequacy, and the **certification decision** remain compliance/privacy/legal/auditor determinations.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

ISO27701-Discovery.ps1

Purpose: Connects to Security & Compliance PowerShell and reports the "what exists today" baseline for the ISO 27701 PIMS program: sensitivity labels and label policies, DLP policies (with mode: test/audit vs enforce), retention labels/policies, the PII sensitive-information types available in the tenant, and the Purview role groups + members (role-separation readiness). Compliance Manager assessments (ISO 27701 / any existing ISO 27001 for reuse) are portal-driven and NOT created here. HOW TO RUN Install-Module ExchangeOnlineManagement -Scope CurrentUser powershell -ExecutionPolicy Bypass -File .\ISO27701-Discovery.ps1 Sign in as a least-privilege Compliance Administrator / Compliance Data Administrator. EXPECTED RESULTS Lists of labels (name, priority, encryption), label policies, DLP policies (name + MODE — flags any already enforcing), retention labels/policies, matching PII SITs, and Purview role groups with member counts. Read-only — makes no changes. .NOTES White-label — Purview Solutions. Read-only. Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy / Get-ComplianceTag / Get-DlpSensitiveInformationType / Get-RoleGroup / Get-RoleGroupMember. > [CmdletBinding()] param()

How to run: Install-Module ExchangeOnlineManagement -Scope CurrentUser powershell -ExecutionPolicy Bypass -File .\ISO27701-Discovery.ps1 Sign in as a least-privilege Compliance Administrator / Compliance Data Administrator. EXPECTED RESULTS Lists of labels (name, priority, encryption), label policies, DLP policies (name + MODE — flags any already enforcing), retention labels/policies, matching PII SITs, and Purview role groups with member counts. Read-only — makes no changes. .NOTES White-label — Purview Solutions. Read-only. Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy / Get-ComplianceTag / Get-DlpSensitiveInformationType / Get-RoleGroup / Get-RoleGroupMember. > [CmdletBinding()] param()

ISO27701-EvidenceReport.ps1

Purpose: Produces the cross-control evidence the program records in `ISO 27701 Evidence – Register`: (1) the sensitivity-label inventory (classification / security-of-processing evidence), (2) a DLP service/mode matrix over PII, (3) recent DLP events from the unified audit log grouped by workload (the audit-gate data), and (4) a small audit-log sample proving accountability logging is on. Optionally exports to CSV. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ISO27701-EvidenceReport.ps1 -Days 7 -CsvPath C:\Temp\iso27701-evidence.csv Sign in as a Compliance Administrator when prompted. Requires audit logging enabled (Requirement 2.8) for the event sections to return data. EXPECTED RESULTS A label inventory, a DLP location/mode matrix, a per-workload DLP-event count, and an audit-log sample for the window — optionally saved to CSV for the evidence register. .NOTES White-label — Purview Solutions. Read-only. Uses Get-Label / Get-DlpCompliancePolicy and Search-UnifiedAuditLog (DLP + sample records). > [CmdletBinding()] param([int]$Days = 7, [string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\ISO27701-EvidenceReport.ps1 -Days 7 -CsvPath C:\Temp\iso27701-evidence.csv Sign in as a Compliance Administrator when prompted. Requires audit logging enabled (Requirement 2.8) for the event sections to return data. EXPECTED RESULTS A label inventory, a DLP location/mode matrix, a per-workload DLP-event count, and an audit-log sample for the window — optionally saved to CSV for the evidence register. .NOTES White-label — Purview Solutions.

Read-only. Uses Get-Label / Get-DlpCompliancePolicy and Search-UnifiedAuditLog (DLP + sample records). > [CmdletBinding()] param([int]$Days = 7, [string]$CsvPath)

ISO27701-Remediation.ps1

Purpose: Remediates the low-risk gaps ISO27701-Validation.ps1 finds — enabling a published-but-off label policy and enabling a disabled retention policy — WITHOUT ever switching a DLP policy to enforce (the audit gate is a human decision) and without deleting anything. Runs in -WhatIf by default; pass -Apply to make the two safe changes. It only REPORTS DLP policies still in test/audit for the operator to promote manually. HOW TO RUN Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\ISO27701-Remediation.ps1 Apply changes: powershell -ExecutionPolicy Bypass -File .\ISO27701-Remediation.ps1 -Apply Sign in as a Compliance Administrator when prompted. EXAMPLE .\ISO27701-Remediation.ps1 -WhatIf EXPECTED RESULTS A list of proposed actions (WhatIf) or the applied changes (-Apply). DLP enforce is never automated; retention is enabled but never created or deleted. .NOTES White-label — Purview Solutions. Default is a dry run. Uses Get-/Set-LabelPolicy and Get-/Set-RetentionCompliancePolicy; reads Get-DlpCompliancePolicy. > [CmdletBinding()] param([switch]$Apply, [string]$LabelPolicyName = 'Label Policy - PII (PIMS) - All Users', [string]$RetentionPolicyName = 'Retention Policy - PII - Retention Limitation') $WhatIf = -not $Apply $mode = $(if($WhatIf){'WHATIF (preview only)'}else{'APPLY'})

How to run: Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\ISO27701-Remediation.ps1 Apply changes: powershell -ExecutionPolicy Bypass -File .\ISO27701-Remediation.ps1 -Apply Sign in as a Compliance Administrator when prompted. EXAMPLE .\ISO27701-Remediation.ps1 -WhatIf EXPECTED RESULTS A list of proposed actions (WhatIf) or the applied changes (-Apply). DLP enforce is never automated; retention is enabled but never created or deleted. .NOTES White-label — Purview Solutions. Default is a dry run. Uses Get-/Set-LabelPolicy and Get-/Set-RetentionCompliancePolicy; reads Get-DlpCompliancePolicy. > [CmdletBinding()] param([switch]$Apply, [string]$LabelPolicyName = 'Label Policy - PII (PIMS) - All Users', [string]$RetentionPolicyName = 'Retention Policy - PII - Retention Limitation') $WhatIf = -not $Apply $mode = $(if($WhatIf){'WHATIF (preview only)'}else{'APPLY'})

ISO27701-Set-Scope.ps1

Purpose: Creates or updates the Microsoft Entra security group used to pilot and then expand the ISO 27701 PIMS program ('ISO 27701 - Pilot Scope') and, optionally, adds a supplied list of pilot users. This is the scope every high-impact control (label, DLP, retention) targets before tenant-wide expansion. Runs in -WhatIf by default; pass -Apply to make changes. It never deletes the group or removes members. HOW TO RUN Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\ISO27701-Set-Scope.ps1 Apply (create/update): powershell -ExecutionPolicy Bypass -File .\ISO27701-Set-Scope.ps1 -Apply Add members: .\ISO27701-Set-Scope.ps1 -Apply -Members user1@contoso.com,user2@contoso.com Sign in with a Groups Administrator (or better) when Connect-MgGraph prompts. EXAMPLE .\ISO27701-Set-Scope.ps1 -WhatIf EXPECTED RESULTS Reports whether the group exists and what would change (WhatIf) or creates/updates it (-Apply), then reports membership. Use the group as the pilot scope in the label/DLP/retention policies. .NOTES White-label — Purview Solutions. Default is a dry run. PowerShell 5.1+/7+. Microsoft Graph: Group.ReadWrite.All (+ User.Read.All to resolve members). No credentials in code. > [CmdletBinding()] param([string] $GroupName = 'ISO 27701 - Pilot Scope', [string] $MailNickname = 'iso27701-pilot-scope', [string[]]$Members, [switch] $Apply, [switch] $WhatIf) $doApply = $Apply -and -not $WhatIf $mode = $(if($doApply){'APPLY'}else{'WHATIF (preview only)'})

How to run: Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\ISO27701-Set-Scope.ps1 Apply (create/update): powershell -ExecutionPolicy Bypass -File .\ISO27701-Set-Scope.ps1 -Apply Add members: .\ISO27701-Set-Scope.ps1 -Apply -Members user1@contoso.com,user2@contoso.com Sign in with a Groups Administrator (or better) when Connect-MgGraph prompts. EXAMPLE .\ISO27701-Set-Scope.ps1 -WhatIf EXPECTED RESULTS Reports whether the group exists and what would change (WhatIf) or creates/updates it (-Apply), then reports membership. Use the group as the pilot scope in the label/DLP/retention policies. .NOTES White-label — Purview Solutions. Default is a dry run. PowerShell 5.1+/7+. Microsoft Graph: Group.ReadWrite.All (+ User.Read.All to resolve members). No credentials in code. > [CmdletBinding()] param([string] $GroupName = 'ISO 27701 - Pilot Scope', [string] $MailNickname = 'iso27701-pilot-scope', [string[]]$Members, [switch] $Apply, [switch] $WhatIf) $doApply = $Apply -and -not $WhatIf $mode = $(if($doApply){'APPLY'}else{'WHATIF (preview only)'})

ISO27701-Validation.ps1

Purpose: Verifies the objects this program deploys are present: the PII label policy is published, the PII DLP policy exists (and reports its mode so you can see whether it has passed the audit gate into enforce), and the PII retention policy exists and is enabled. Pass/fail per the Testing Guide — read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ISO27701-Validation.ps1 Sign in as a Compliance Administrator when prompted. Optionally pass -LabelPolicyName / -DlpPolicyName / -RetentionPolicyName to match your renamed objects. EXPECTED RESULTS "VALIDATION PASSED" when the label policy is enabled, the DLP policy is present, and the retention policy is enabled. Exit code 0 on pass, 1 on any gap. .NOTES White-label — Purview Solutions. Read-only. Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy. > [CmdletBinding()] param([string]$LabelPolicyName = 'Label Policy - PII (PIMS) - All Users', [string]$DlpPolicyName = 'DLP Policy - PII (PIMS)', [string]$RetentionPolicyName = 'Retention Policy - PII - Retention Limitation')

How to run: powershell -ExecutionPolicy Bypass -File .\ISO27701-Validation.ps1 Sign in as a Compliance Administrator when prompted. Optionally pass -LabelPolicyName / -DlpPolicyName / -RetentionPolicyName to match your renamed objects. EXPECTED RESULTS "VALIDATION PASSED" when the label policy is enabled, the DLP policy is present, and the retention policy is enabled. Exit code 0 on pass, 1 on any gap. .NOTES White-label — Purview Solutions. Read-only. Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy. > [CmdletBinding()] param([string]$LabelPolicyName = 'Label Policy - PII (PIMS) - All Users', [string]$DlpPolicyName = 'DLP Policy - PII (PIMS)', [string]$RetentionPolicyName = 'Retention Policy - PII - Retention Limitation')